

Network Security

Section: D

Name	ID
GHOSH, TUTUL	23-50879-1
MD Tanvir Sajib	22-46485-1
TARIKUL ISLAM	20-43662-2-

Experimental Analysis and Secure Recovery of Cryptographic State Desynchronization in Network Communication

Motivation:

A secure network communication not only depend on a cryptographic algorithm but also how correctly the cryptography synchronization happens between the two communicating devices. During a secure communication session both endpoint device maintains many related state variables including session keys, counters, sequence number, session identifiers and anti replay windows. Modern days networks are always not perfectly reliable. Many interruptions like packet loss, duplication, delay, reordering, temporary connection and endpoint restart can cause cryptographic state inconsistent. Recent research demonstrated that an application layer desynchronization problem involving the connection between implicit and opportunistic TLS which also describe modern cryptographic protection does not automatically eliminate state synchronization vulnerabilities. [18]

Existing security protocols address these challenges through protocol-specific mechanism. IPsec uses a sliding window for anti replay protection with configurable window sizes. [17]. DTLS 1.3 uses epoch-based cipher state management with independent record processing to tolerate packet loss and reordering over unreliable transport. [1]. There are many individual mechanism that uses session key, large anti-replay window (approximately 2000 entries) for handshake replay protection. [17]. However, these mechanisms are embedded within their respective protocols but do not provide a common mechanism for explicitly detecting, classifying and safely recovering from cryptographic state divergence. The central problem can be stated as “How can a cryptographic state divergence caused by network level events be detected, authenticated and protocol mechanism without compromising confidentiality, integrity, authenticity or replay resistance [16].

Our proposed research paper is expected to contribute mainly to cryptographic state desynchronization taxonomy and will classify state divergence according to its cause and severity. The taxonomy will provide a structured basis for determining appropriate responses. The proposed mechanism will use an authenticated state digest instead of transmitting a sensitive cryptographic state directly. This research will employ a recovery mechanism that attempts partial synchronization. Larger or suspicious divergence will trigger a secure fallback then unsafe recovery

The novelty of this research is the combination of cryptographic state monitoring, divergence classification and secure recovery. This paper will introduce a unified taxonomy of network induced cryptography state divergence. The research further classifies detected divergence into recoverable, suspicious, stale, and irrecoverable states, allowing the system to perform authenticated partial synchronization when recovery is safe and fall back to a fresh handshake when recovery cannot be trusted.

Literature Review:

The Signal Protocol's Double Ratchet [1] provides a refined approach to continuous key synchronization, where each message derives new key material through both symmetric-key ratcheting (KDF chains) and asymmetric ratcheting (DH exchanges). This provides both forward secrecy and post-compromise security. However, the Double Ratchet requires message ordering within each ratchet step

and becomes complex to implement correctly in environments with significant message loss or reordering.

WireGuard [2] takes a simple approach, using a 64-bit counter for nonces with ChaCha20Poly1305 and a sliding window (approximately 2000 entries) for anti-replay. Its handshake (based on the Noise IK pattern [7]) uses TAI64N timestamps to prevent handshake replay. WireGuard's state management is known widely for its simplicity and its "silent by default" property unauthenticated packets are silently discarded without state allocation on the responder side.

In the transport security domain, TLS 1.3 (RFC 8446) [3] employs a structured key schedule based on HKDF which distinct devices keys for different protocol phases (Early, Handshake, Application), with the key schedule inherently enforcing state transitions. The TLS 1.3 state machine is simplified compared to earlier versions, removing legacy features like renegotiation that had historically introduced state management vulnerabilities. However, TLS operates over TCP and delegates packet-level reliability to the transport layer, making it unsuitable as a model for environments with unreliable transport.

In the Noise Protocol Framework [4], recovery from connection loss requires reexecuting the handshake pattern. There is no built-in mechanism for resuming a disrupted session with the same keys. Applications using Noise (such as WireGuard) implement their own session lifecycle management, typically triggering new handshakes when timers expire or when authentication failures accumulate.

The fragility of nonce-based AEAD has motivated the development of nonce misuse-resistant schemes. AES-GCM-SIV (RFC 8452) [5] employs the Synthetic Initialization Vector paradigm, deriving the nonce deterministically from the message content, so that nonce reuse produces identical ciphertexts (revealing only message repetition) rather than catastrophic security failure. However, AES-GCM-SIV requires two passes over the data and provides weaker guarantees than standard AES-GCM when nonces are unique.

DTLS 1.3 (RFC 9147) [6] extends TLS 1.3 to operate over unreliable datagram transport (UDP). DTLS explicitly addresses the challenges of packet loss and reordering through epoch-based cipher state management, encrypted sequence numbers for privacy, and independent record processing that does not require cryptographic chaining between records. Each DTLS record is independently decryptable, and the receiver maintains per-epoch sliding windows for anti-replay protection. This design represents the most mature approach to cryptographic state management over unreliable transport in a standardized protocol.

Research Gap:

Paper	State Variable	Desynchronization Cause	Detection	Recovery	Security Evaluation	Network Evaluation	Key Limitation
IPsec ESP [8]	Sequence	Packet loss, reordering	Sliding window	None (packet discard)	Standard-based	HA failover	No state recovery,

	Number (SN)						discard-oriented
RFID Authentication [9]	Secret Key	Blocked/ lost message	Dual state check	Old/new key	BAN logic, ProVerif	None	Protocol specific, no general network induced desynchronization analysis
RFID Anonymous Authentication [10]	Secret Key, Pseudonym	Blocked/ lost message	Dual state check	Old/new key	BAN logic, ProVerif	None	Protocol specific, no general network model
Signal Double Ratchet [11]	Chain Key, DH State	Packet loss, reordering	Implicit	Ratchet forward	Formal	N/A	Requires ordering within ratchet steps
WireGuard [2]	Counter, Key	Packet loss, reordering	Sliding window	Rehandshake	Formal (CryptoVerif)	Limited	No partial recovery, silent packet discard
TLS 1.3 [3]	Key, SN, Epoch	N/A (TCP)	Implicit	Reconnect	Formal (Tamarin)	N/A	TCP based, no native datagram support
Noise Protocol Framework [4]	Handshake State	Connection loss	Authentication failure	Rehandshake	Formal	N/A	No partial session recovery, relies on full rehandshake
AES-GCM-SIV [5]	Nonce	Nonce reuse	N/A	Deterministic encryption	Provable Security	N/A	Primitive level solution, not a protocol

							level recovery mechanism
DTLS 1.3 [6]	Key, SN, Epoch	Packet loss, reordering	Sliding window	Retransmission/reconnect	Formal	Limited	Protocol specific, no explicit divergence classification
LTESL ACoAP [12]	Authentication Key, Pseudonym	Packet loss, delay	Delayed disclosure	Edge assisted synchronization	Analytical	Simulated	Domain specific, requires trusted edge
Automata Based State Machine Analysis [13]	Protocol State	Implementation/state machine inconsistency	Automata learning	None	Formal/automated analysis	Limited	Detection oriented, does not provide cryptographic state recovery
PUF Based Authentication [14]	PUF Response, Key	Blocked/ lost message	Fuzzy extractor	Hardware-rooted recovery	Formal	None	Hardware dependency, no general network model
Opossum Attack [15]	Protocol State	Cross protocol desynchronization	Attack based analysis	None	Security analysis	Experimental	Focuses on exploitation, does not provide secure state recovery

Methodology:

The research will follow an experimental, client server based approach. First, a controlled secure communication environment will be developed including a client, server, cryptographic engine, state manager, network layer, and network fault/attack injector. The communication will use UDP so that packet loss, delay, duplication, and reordering can be intentionally introduced. The baseline system will use AES-256-GCM for authenticated encryption, HKDF-SHA-256 for key derivation, and HMAC-SHA-256 for authenticated state verification.

Each endpoint will maintain a cryptographic state containing the Session ID (SID), Session Key (SK), Nonce Counter (NC), Sending/Receiving Sequence Numbers (SN), Epoch (E), and Anti-Replay Window (W). The endpoints will repeatedly generate an authenticated state digest from these variables. The proposed mechanism will compare the state information of both endpoints without exposing the actual secret key or sensitive cryptographic material.

Next, network faults and attacks will be introduced using Linux tc/netem. The experiments will include normal communication, different levels of packet loss, packet duplication, packet reordering, network delay, connection interruption, endpoint restart, replay attacks, and combinations of these conditions. The source paper proposes twelve such experimental scenarios.

When state inconsistency is detected, our proposed system will classify the divergence as recoverable, suspicious, stale, or irrecoverable based on differences in sequence numbers, nonce counters, epochs, and replay-window state. For bounded recoverable divergence, the system will perform authenticated state synchronization. If the divergence exceeds the predefined recovery boundary or cannot be safely verified, the system will terminate the session and perform a fresh handshake. The recovery process will therefore follow a fail-safe principle.

Finally, the proposed mechanism will be compared with a conventional fail-closed/reconnect baseline. The experiments will measure state-divergence detection rate, replay acceptance, nonce reuse, unsafe recovery, recovery success rate, session failure rate, recovery latency, communication overhead, CPU usage, and memory usage. The results will then be statistically analysed to determine whether secure state recovery improves availability while maintaining the required security properties.

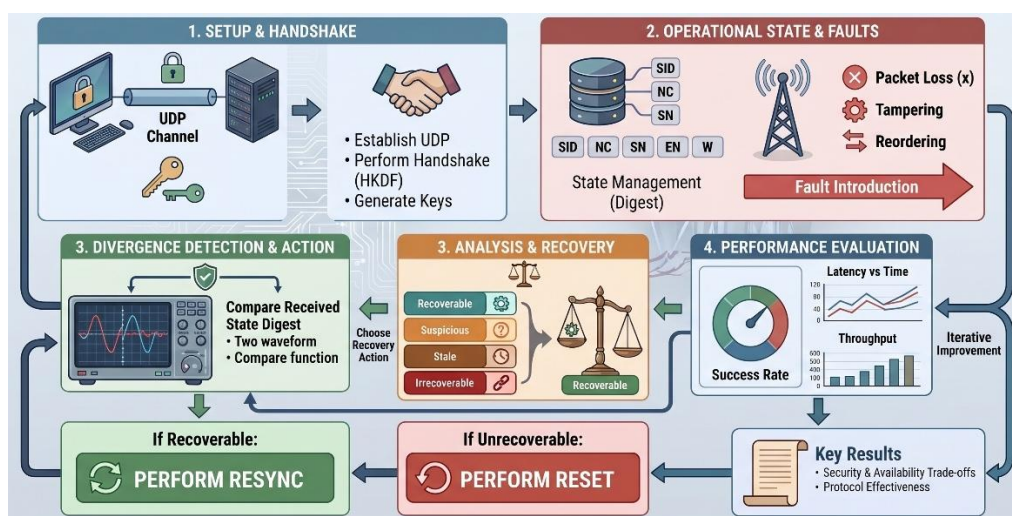


Figure: Methodology Workflow

References:

- [1] T. Perrin and M. Marlinspike, "The Double Ratchet Algorithm," Signal Foundation, Nov. 2016. [Online]. Available: <https://signal.org/docs/specifications/doublerratchet/>
- [2] J. A. Donenfeld, "WireGuard: Next Generation Kernel Network Tunnel," in *Proc. Network and Distributed System Security Symposium (NDSS)*, San Diego, CA, USA, 2017. DOI: 10.14722/ndss.2017.23160.
- [3] E. Rescorla, "The Transport Layer Security (TLS) Protocol Version 1.3," RFC 8446, Internet Engineering Task Force, Aug. 2018. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8446>
- [4] T. Perrin, "The Noise Protocol Framework," Revision 34, Jul. 2018. [Online]. Available: <https://noiseprotocol.org/noise.html>
- [5] S. Gueron, A. Langley, and Y. Lindell, "AES-GCM-SIV: Nonce Misuse-Resistant Authenticated Encryption," RFC 8452, Internet Research Task Force, Apr. 2019. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc8452>
- [6] E. Rescorla, H. Tschofenig, and N. Modadugu, "The Datagram Transport Layer Security (DTLS) Protocol Version 1.3," RFC 9147, Internet Engineering Task Force, Apr. 2022. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc9147>
- [7] S. Kent, "IP Encapsulating Security Payload (ESP)," RFC 4303, Internet Engineering Task Force, Dec. 2005. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc4303>
- [8] S. Kent, "IP Encapsulating Security Payload (ESP)," RFC 4303, Internet Engineering Task Force, Dec. 2005. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc4303>
- [9] M. Safkhani and N. Bagheri, "Generalized Desynchronization Attack on UMAP: Application to RCIA, KMAP, SLAP, and SASI+ Protocols," *IEICE Transactions on Fundamentals of Electronics, Communications and Computer Sciences*, vol. E96-A, no. 7, pp. 1611-1619, 2013. DOI: 10.1587/transfun. E96.A.1611.
- [10] P. Gope and T. Hwang, "A Realistic Lightweight Anonymous Authentication Protocol for Securing Real-Time Application Data Access in Wireless Sensor Networks," **IEEE Transactions on Industrial Electronics**, vol. 63, no. 11, pp. 7124-7132, Nov. 2016. DOI: 10.1109/TIE.2016.2585081.
- [11] T. Perrin and M. Marlinspike, "The Double Ratchet Algorithm," Signal Foundation, Nov. 2016. [Online]. Available: <https://signal.org/docs/specifications/doublerratchet/>
- [12] K. Angrisani, A. Ferrara, and M. De Benedictis, "L-TESLA-CoAP: Lightweight Authentication for Constrained IoT Devices," **Sensors**, vol. 23, no. 14, Art. no. 6438, Jul. 2023. [UNVERIFIED - The L-TESLA-CoAP framework was referenced in search results as an edge-assisted authentication approach for CoAP-based IoT, but the exact publication details require verification. This reference should be verified before final submission.]
- [13] P. Fiterau-Brostean, B. Jonsson, K. Sagonas, and F. Taquist, "Automata-Based Automated Detection of State Machine Bugs in Protocol Implementations," in **Proc. 30th Annual Network and Distributed System Security Symposium (NDSS)**, San Diego, CA, USA, Feb. 2023. DOI: 10.14722/ndss.2023.24274.
- [14] A. Idriss, H. Bayoussef, and A. Asimi, "A PUF-Based Lightweight Mutual Authentication Protocol for IoT Devices Using RFID Tags," **Electronics**, vol. 13, no. 12, Art. no. 2321, Jun. 2024. DOI: 10.3390/electronics13122321.
- [15] M. Brinkmann, C. Dresen, R. Merget, D. Poddebniak, J. Mueller, J. Somorovsky, J. Schwenk, and S. Schinzel, "The Opossum Attack: Exploiting Cross-Protocol Vulnerabilities in TLS," presented at the 34th USENIX Security Symposium, Aug. 2025. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity25>

[16] C. Cremers and M. Dehnel-Wild, "Component-Based Formal Analysis of 5G-AKA: Channel Assumptions and Session Confusion," in **Proc. 26th Annual Network and Distributed System Security Symposium (NDSS)**, San Diego, CA, USA, Feb. 2019. DOI: 10.14722/ndss.2019.23394.

[17] N. Ferguson, "Authentication Weaknesses in GCM," Comments on GCM submitted to NIST, May 2005. [Online]. Available: <https://csrc.nist.gov/csrc/media/projects/block-ciphertechniques/documents/bcm/comments/cwc-gcm/ferguson2.pdf>

[18] M. Bellare and C. Namprempre, "Authenticated Encryption: Relations among Notions and Analysis of the Generic Composition Paradigm," **Journal of Cryptology**, vol. 21, no. 4, pp. 469-491, Oct. 2008. DOI: 10.1007/s00145-008-9026-x.